

Especificação Técnica & Requisitos

Gerenciador de Senhas Offline (MVP) • Arquitetura e Critérios de Aceitação

1. Visão Geral do Produto

O sistema consiste em uma aplicação mobile focada em privacidade e segurança estritamente local (*offline-first*), desenvolvida utilizando a plataforma Expo (React Native). O aplicativo segue o princípio de **Zero-Knowledge**, garantindo que o controle das credenciais e chaves criptográficas pertença única e exclusivamente ao dispositivo físico do usuário. Não existem mecanismos de recuperação de senha por nuvem ou servidores externos, tornando a integridade dos dados inviolável contra vazamentos remotos de dados.

2. Stack Tecnológica e Componentes Nativos

Categoria	Tecnologia	Justificativa / Papel na Arquitetura
Framework Base	Expo (React Native)	Compilação nativa de alta performance e ecossistema consolidado de acesso a APIs de hardware.
Roteamento	Expo Router	Arquitetura de rotas baseada em arquivos, utilizando <i>Route Groups</i> para isolamento estrito de fluxos autenticados.
Cofre Local	react-native-mmkv	Armazenamento síncrono de altíssima velocidade com suporte nativo a criptografia AES orientada a C++.
Chaves de Hardware	expo-secure-store	Isolamento do hash do PIN e chaves mestras dentro do Keystore (Android) e Keychain (iOS).
Criptografia	expo-crypto	Geração de entropia matemática (chaves aleatórias de 256-bits) e hashing criptográfico seguro (SHA-256).
Estado Global	Zustand	Gerenciamento reativo de memória volátil, sincronizado ao ciclo de vida de atividade do app.
Formulários	react-hook-form + Zod	Validação estrutural estrita em tempo de execução e tipagem estática integrada via TypeScript.

3. Arquitetura de Segurança (Sistema de Duas Chaves)

Para mitigar riscos de engenharia reversa e ataques de força bruta no banco de dados local (especialmente em cenários onde o dispositivo sofreu privilégios de *root* ou *jailbreak*), o PIN definido pelo usuário **não é utilizado diretamente** como chave de cifragem.

- **Chave Mestra (Master Key):** No primeiro acesso, o expo-crypto gera uma chave criptográfica forte aleatória de 256-bits. Esta chave é armazenada no expo-secure-store sob a diretriz de acessibilidade WHEN_UNLOCKED_THIS_DEVICE_ONLY (bloqueada nativamente se o celular estiver travado).
- **Hash do PIN:** O PIN numérico inserido pelo usuário recebe a adição de um *salt* estático da aplicação, passa pelo algoritmo SHA-256 e o hash resultante é salvo no Secure Store apenas para fins de comparação lógica no desbloqueio.
- **Inicialização Segura:** O banco MMKV é criptografado nativamente com a Master Key de 256-bits. O Zustand lê os dados descriptografados do MMKV unicamente após a validação bem-sucedida do PIN, mantendo o array de senhas limpo em estados de bloqueio.

Nota de Segurança Crítica

Caso o usuário esqueça o PIN de acesso local, os dados tornam-se criptograficamente irre recuperáveis por design, respeitando os padrões de criptografia militar de ponta a ponta.

4. Modelagem de Dados e Roteamento

4.1 Schema de Validação (Zod Schema)

```
import { z } from 'zod';

export const CredentialSchema = z.object({
  id: z.string().uuid(),
  label: z.string().min(2, "O nome do serviço deve ter pelo menos 2 caracteres"),
  username: z.string().optional(),
  password: z.string().min(1, "A senha não pode estar vazia"),
  createdAt: z.number(),
  updatedAt: z.number(),
});

export type Credential = z.infer<typeof CredentialSchema>;
```

4.2 Estrutura de Diretórios e Rotas (Expo Router)

```
app/
├── (auth)/                # Grupo Público (Barreira de Proteção)
│   ├── pin-setup.tsx      # Configuração inicial e geração de chaves
│   └── unlock.tsx         # Tela de autenticação por PIN/Biometria
└── (app)/                 # Grupo Privado (Protegido por Estado Seguro)
    ├── _layout.tsx        # Drawer / Stack protegida por Contexto de Autenticação
    ├── vault.tsx          # Tela principal: listagem mascarada e cópia rápida
    └── create.tsx         # Formulário de criação e gerador customizável
```

5. Critérios de Aceitação (Histórias de Usuário)

Épico 1: Autenticação Inicial e Gerenciamento de Sessão

1.1 Configuração de Primeiro Acesso: Dado que o usuário instala e abre o aplicativo pela primeira vez, quando a aplicação for inicializada, então o fluxo deve interceptar a navegação e forçar o registro obrigatório de um PIN de 6 dígitos, gerando a Master Key criptográfica e o Hash do PIN em background.

1.2 Barreira de Desbloqueio: Dado que o PIN já está configurado no dispositivo, quando o aplicativo for inicializado a partir de um estado fechado, então as rotas protegidas contidas no grupo (app) devem permanecer inacessíveis até que a validação do PIN ou Biometria seja concluída com sucesso na tela / unlock.

1.3 Ciclo de Vida em Background: Dado que o aplicativo encontra-se desbloqueado e em uso pelo usuário, quando o sistema operacional disparar o evento de minimização (AppState modificado para background ou inactive), então o Zustand deve purgar imediatamente o array de credenciais da memória RAM e o Expo Router deve redirecionar o foco para a rota /unlock de forma síncrona.

Épico 2: Gestão do Cofre de Senhas (CRUD)

2.1 Validação de Inserção: Dado que o usuário está no formulário de inclusão de credenciais, quando submeter o formulário de salvamento, então o mecanismo baseado no Zod Schema deve invalidar a operação se os campos correspondentes ao Label e Password não atenderem aos critérios mínimos de preenchimento.

2.2 Mascaramento Padrão de Dados: Dado que o usuário está visualizando sua lista de senhas salvas na tela /vault, quando a listagem for renderizada, então todos os valores textuais do campo password devem ser exibidos de forma mascarada (ex: ••••••••), preservando a legibilidade apenas para Label e Username.

2.3 Ação de Cópia Ágil: Dado que o usuário deseja utilizar uma credencial armazenada, quando o mesmo acionar o ícone de cópia rápida posicionado ao lado do registro, então a senha em texto claro deve ser injetada no Clipboard do sistema operacional e um alerta visual temporário (Toast) deve notificar a conclusão.

Épico 3: Gerador Avançado e Parametrizável de Senhas

3.1 Granularidade de Parâmetros: Dado que a interface do gerador de senhas está ativa, então devem ser disponibilizados controles do tipo slider para extensão numérica do comprimento da string, além de chaves seletoras (switches) para inclusão seletiva de: letras maiúsculas, minúsculas, caracteres numéricos e símbolos especiais.

3.2 Restrição de Segurança Mínima: Dado que o usuário manipula as configurações de caracteres, quando tentar desativar cumulativamente todas as chaves seletoras, então o sistema deve bloquear o desabafo da última chave ativa, prevenindo a geração de strings de entropia nula.

3.3 Predefinições de Formato (Templates): Dado que o usuário seleciona um modelo pré-configurado rápido (ex: "PIN de Banco - 6 Dígitos"), quando o gatilho for acionado, então os seletores devem se reconfigurar automaticamente (apenas numérico ativo, comprimento fixado em 6) e uma nova senha válida deve preencher a tela instantaneamente.

Épico 4: Engenharia Anti-Intrusão e Prevenção contra Vazamentos

4.1 Volatilidade do Clipboard (Time-To-Live): Dado que uma senha foi copiada para a área de transferência do sistema (Critério 2.3), quando o contador regressivo interno da aplicação atingir o limite estrito de 45 segundos, então o aplicativo deve invocar nativamente a limpeza ou sobrescritura do Clipboard por caracteres vazios.

4.2 Proteção de Estado Visual no Multitarefa: Dado que o aplicativo está ativo, quando o usuário invocar o painel de alternância de aplicativos abertos do sistema operacional (App Switcher), então a janela do app deve ser coberta por um overlay opaco e capturas de tela devem ser bloqueadas nativamente via hardware (FLAG_SECURE no Android).

4.3 Mitigação de Força Bruta (Rate Limit): Dado que sucessivas tentativas inválidas de PIN ocorrem na rota /unlock, quando o contador computar 5 erros consecutivos, então a interface de login deve ser congelada por 60 segundos, persistindo o timestamp de bloqueio no armazenamento base para prevenir bypass por reinicialização forçada do app.

4.4 Encerramento por Inatividade Local: Dado que o aplicativo permanece ativo e em primeiro plano, quando nenhum evento de toque ou rolagem de tela for detectado por um período contínuo de 3 minutos, então o estado do Zustand deve ser limpo e o usuário deve ser redirecionado automaticamente para a rota /unlock.